



File No.: EXP202300742

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. B.B.B. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on November 30, 2022. The complaint is directed against ARA-FISIOMÉDICA, S.L. with NIF B50878875 (hereinafter, FISIOMÉDICA). The reasons for the complaint are as follows:

The sending, on November 28, 2022, of an email addressed to multiple recipients, including the complainant, without using the BCC functionality.

All recipients are presumed to be clients of the aesthetic group to whom the communication is sent, in which they are informed that the aesthetic clinic they were users of will be closing.

A copy of the sent email is attached to the complaint.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to FISIOMÉDICA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) through electronic notification, was not collected by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP on February 7, 2022, as stated in the certificate in the file.

THIRD: On February 28, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/8

FOURTH: On May 24, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the accused party for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

FIFTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and after the period granted for the submission of allegations had elapsed, it has been confirmed that no allegations have been received from the accused party.

Article 64.2.f) of the LPACAP - a provision of which the accused party was informed in the initiation agreement - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the accused party, and the sanction that could be imposed. Therefore, considering that the accused party has not made any allegations regarding the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts to be proven,

PROVEN FACTS

FIRST: It is evidenced in the file that Ms. B.B.B. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection against FISIOMÉDICA on November 30, 2022.

SECOND: It has been evidenced in the file that on November 28, 2022, an email was sent from info@clnicaspastor.es to multiple recipients, including the complainant, without using the BCC functionality.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with the provisions of Article 4.1 of the GDPR, it is established that there is a processing of personal data, since FISIOMÉDICA carries out, among other processes, the collection, storage, and use of the following personal data of individual clients of the aesthetic center, such as: name and surname, ID number, phone number, email address, postal address.

FISIOMÉDICA carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of the aforementioned Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances indicated above, categorized as a confidentiality breach; as a consequence of sending an email, in which all the email addresses of the recipients can be seen in the unhidden copy.

The security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which regulate both the security of processing, the notification of a personal data security breach to the supervisory authority, as well as the communication to the data subject, respectively.

III

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In this case, it is established that there has been unauthorized access to the email addresses of the recipients, violating the principle of confidentiality, as an email was sent in which all the email addresses of the recipients could be seen in the unhidden copy, which constitutes a violation of Article 5.1.f) of the GDPR.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 a) of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a limitation period of three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to graduate the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

It is also considered appropriate to adjust the sanction to be imposed according to the criteria established in section 2 of article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

-

b) The connection of the infringer's activity with the processing of personal data.

The party being claimed is engaged in aesthetic medicine, a professional activity subject to the duty of confidentiality regarding clients, which involves continuous processing of data.

In aesthetic centers, a significant amount of personal information related to their patients is collected, which may include data related to their health.

The balance of the circumstances contemplated in article 83.2 of the GDPR and article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions of article 5.1.f) of the GDPR, allows for the imposition of a sanction of €2,000 (TWO THOUSAND EUROS).

VI

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, as appropriate:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to article 40 or to an approved certification mechanism pursuant to article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/8

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

In the present case, at the time of the breach, it is evident that FISIOMÉDICA lacked reasonable security measures based on the estimated potential risks, as well as that the information and training directed at the staff who were to carry out the processing of personal data were entirely insufficient, specifically regarding the sending of emails, which constitutes a violation of article 32 of the GDPR.

VII

Classification of the infringement of article 32 of the GDPR

The aforementioned infringement of article 32 of the GDPR constitutes the commission of the infringements classified in article 83.4 a) of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to €10,000,000 or, in the case of an undertaking, an amount equivalent to 2% of the total global annual turnover of the preceding financial year, whichever is higher:

- a) the obligations of the controller and the processor under articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its article 71 “Infringements” establishes that “Acts and conduct referred to in paragraphs 4, 5, and 6 of article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a limitation period of two years:

...

- f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by article 32.1 of Regulation (EU) 2016/679.

C/ Jorge Juan, 6

Sanction for the violation of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to graduate the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR.

Furthermore, it is considered appropriate to graduate the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

-

b) The connection of the infringer's activity with the processing of personal data.

The entity in question is engaged in aesthetic medicine, a professional activity subject to the duty of confidentiality regarding clients, which involves continuous processing of data.

In aesthetic centers, a significant amount of personal information related to their patients is collected, which may include data related to their health.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the violation committed by breaching the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €1,000 (ONE THOUSAND EUROS).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ARA-FISIOMÉDICA, S.L., with NIF B50878875,

- For a violation of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, a fine of TWO THOUSAND EUROS (€2,000).

- For a violation of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of ONE THOUSAND EUROS (€1,000).

SECOND: TO NOTIFY this resolution to ARA-FISIOMÉDICA, S.L.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

FOURTH: To warn the sanctioned party that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next

business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es